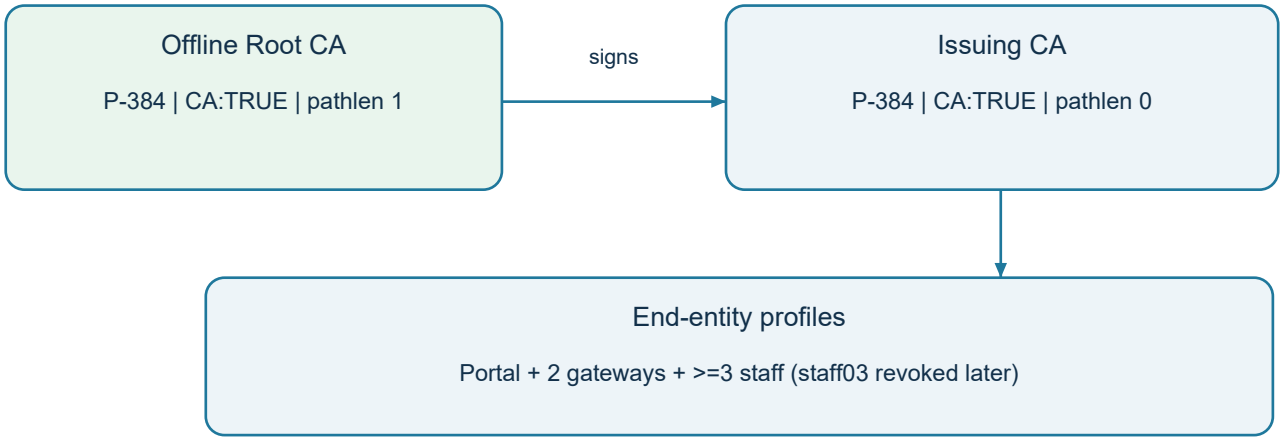
PKI Design

Group 03 | Design only; no certificates or private keys generated

Hierarchy and naming

PKI (Public Key Infrastructure) binds identities to public keys through signed certificates. The offline Root CA signs the Issuing CA certificate and Root CRL only. The Issuing CA signs portal, gateway and staff certificates and its own CRL. Services trust the Root public certificate; servers send leaf plus Issuing certificate, usually omitting the Root trust anchor. CN labels identity; SAN is authoritative for endpoint names.



All key choices below are proposals within specification section 6. KU means Key Usage; EKU means Extended Key Usage; SAN means Subject Alternative Name; BC means Basic Constraints. CA certificates are not end entities. AKI/SKI identify issuer/subject keys; serials are random positive unique 128-bit values checked against the CA database. No real member email addresses are invented: staff SAN emails below are lab-only identities.

Profile / Subject	SAN / key	Extensions / validity
root / CN=AABU SCP Root CA g03	No SAN required; ECDSA P-384	critical BC CA:TRUE,pathlen:1; critical KU keyCertSign,cRLSign; SKI/AKI; no EKU. 1825 days, <=5 years at issuance.
issuing / CN=AABU SCP Issuing CA g03	No SAN required; ECDSA P-384	critical BC CA:TRUE,pathlen:0; critical KU keyCertSign,cRLSign; SKI/AKI; Root CRL DP. 730 days, capped at parent expiry and <=2 years.
portal / CN=portal.g03.scp.lab	DNS portal.g03.scp.lab, pki.g03.scp.lab; ECDSA P-256	critical BC CA:FALSE; critical KU digitalSignature; EKU serverAuth; Issuing CRL DP; SKI/AKI. 365 days <=398 and issuer expiry.
gateway-hq / CN=gw-hq.g03.scp.lab	DNS gw-hq.g03.scp.lab; IP 172.16.3.10; ECDSA P-256	critical BC CA:FALSE; critical KU digitalSignature; EKU id-kp-ipsecIKE (1.3.6.1.5.5.7.3.17), compatibility pending; Issuing CRL DP; SKI/AKI. 365 days <=398.

Profile / Subject	SAN / key	Extensions / validity
gateway-branch / CN=gw-branch.g03.scp.lab	DNS gw-branch.g03.scp.lab; IP 172.16.3.20; ECDSA P-256	Same gateway constraints; exact peer FQDN pinning independent of CA trust. 365 days <=398.
staff01, staff02, staff03 / CN=staffNN	email staffNN@g03.scp.lab; ECDSA P-256	critical BC CA:FALSE; critical KU digitalSignature; EKU clientAuth; Issuing CRL DP; SKI/AKI. 365 days, <=1 year and issuer expiry.

At least THREE staff certificates are mandatory even with the approved two-member group. staff01 and staff02 are distinct lab principals; staff03 is a test principal to be revoked, not a claimed third member. No certificate is shared by people. Planned inventory has Root, Issuing, portal, two gateways and three staff certificates (8 minimum legitimate certificates). Rogue CA/certificate are later isolated attack artifacts, never installed in host/real-browser trust.

Gateway EKU is a proposed purpose-specific restriction, not a substitute for exact identity matching. Test the Ubuntu strongSwan 5.9+ build against id-kp-ipsecIKE and reject staff clientAuth certificates. If this EKU is not enforced by the selected build, document the compatible profile and require explicit gateway-purpose/identity checks before accepting the design. Do not silently broaden trust to every CA-issued leaf.

Secret placement and classification

Artifact	Classification / location / access
Root key and passphrase	SECRET. Encrypted offline storage outside project folder, Docker build context and all /work mounts; signing workstation only; Unix mode 600 and restrictive parent directory. Passphrase entered interactively.
Issuing key / CA database backup	Key SECRET, database INTERNAL. Controlled signing workspace outside service mounts; encrypted backup, mode 600, offline between operations where feasible.
Portal / gateway / staff private keys	SECRET. Per-role runtime secret mounts only in future stages, owner-read/write 600; never mounted wholesale across all six nodes. No secret creation in M1.
Root/Issuing/leaf certificates and CRLs	PUBLIC. Reviewed public certificate/CRL files may enter Git; fingerprints independently checked before trust.
Profiles, topology and configuration	INTERNAL. Private repository. Lab principal identifiers are test data.
PCAPs, logs, TLS key logs	Baseline synthetic PCAP INTERNAL; review before commit. Key logs SECRET, never Git, delete after isolated exercise. No real credentials in traffic.

Windows bind-mount permissions do not establish Linux mode 600 by themselves. Future secret creation uses Linux-controlled storage with observed ownership/permissions; Windows ACLs and backup access also checked. Root exclusion is by physical storage placement, not .gitignore alone.

Issuance workflow (planned M2)

1. Create separate encrypted Root and Issuing keys; verify profiles and parent-expiry caps. Root signs only Issuing CA and Root CRL, then goes offline.

2. Generate each end-entity private key at its authorized role, create CSR, validate allowed identity/SAN/profile independently of CSR requests, sign with Issuing CA.

3. Write pki/certs_inventory.md with serial, Subject, SAN, issuer, notBefore/notAfter, profile and revocation state. Inspect extensions and verify chains/purposes.

4. Transfer only role-specific credentials; publish public chains/CRLs; test valid, wrong-name, wrong-purpose, untrusted, expired and revoked credentials. No pki implementation is included in M1.

Revocation and CRL publication

CRL (Certificate Revocation List) is a signed list of revoked serials; OCSP answers per-certificate status online. CRLs work with this offline-capable lab but can be stale. OCSP introduces an online dependency and is not substituted for the mandatory CRL. Soft-fail means accepting a credential when revocation status cannot be checked; this design rejects unknown status.

Proposed Issuing CRL validity: 24 hours; regenerate before half-life and immediately on revocation. Publish atomically at http://pki.g03.scp.lab/crl/issuing.crl (DER for distribution), retain PEM for local validators. Proposed Root CRL: 30 days, refreshed via offline signing before half-life and immediately upon Issuing compromise; publish /crl/root.crl. Both carry thisUpdate, nextUpdate, issuer, CRL number and valid signature. Root and Issuing CRLs are supplied wherever intermediate revocation must be checked.

HTTP CRL distribution is an explicit exception to portal redirect, avoiding a circular TLS-validation dependency. Verify CRL signature, issuer and freshness on import. nginx uses a locally managed PEM bundle via ssl_crl; it does not fetch CRL URLs automatically. Refresh/reload must be monitored. strongSwan strict revocation policy with cached/prefetched CRLs must be tested on the selected build; establish initial CRL availability before protected access.

Missing or expired CRL: refuse new staff authentication and new IKE authentication; alert and refresh rather than continue silently. Existing TLS sessions/IKE SAs may survive a CRL update; revocation procedure invalidates resumptions, closes relevant TLS connections and terminates affected IKE SAs, then verifies reconnect refusal. Missing CRL can prevent nginx reload while old workers still run, so a successful file copy/reload attempt alone is insufficient: check effective policy and stop protected service if freshness cannot be guaranteed.

Revocation exercise: revoke staff03, update/publish CRL, deploy and reload, verify staff01 succeeds and staff03 fails; repeat with a test gateway certificate in later milestones. Evidence includes dated inventory, serial, openssl crl -text, valid nextUpdate, nginx/strongSwan logs and negative tests. Nothing in this plan is reported as executed.